

Secure Configuration Standard

STANDARD NUMBER: DAS-ITS-2100-09-A	EFFECTIVE DATE: 04/30/2020	APPROVED BY: Anupam Srivastava, State Chief Information Security Officer
REPLACES STANDARD DATED: n/a	AUTHORITY: Ohio Revised Code 125.18 Office of Information Technology - duties of director - contracts, Ohio IT Standard ITS-SEC-02, "Security Controls Framework"	

1.0 Purpose

The purpose of this standard is to provide requirements to Ohio Department of Administrative Services (DAS) technical teams that will allow for the consistent implementation of secure configuration standards across **DAS-managed information systems**.

2.0 Scope

The scope of this standard includes any DAS-managed information system. This standard represents the minimum acceptable secure configuration standards for hardware and software for **portable computing devices**, workstations, servers, **cloud computing services**, and network, storage, and print devices.

This policy also applies to DAS data owners, service owners, and to **external service providers**.

3.0 Standard

3.1 Minimum Secure Configuration Requirements

The following minimum secure configuration standards shall be applied to information systems that are developed or acquired by DAS:

- 3.1.1 Systems shall be **hardened**, including the underlying operating system and the applications installed on the system, in accordance with the applicable published Center for Internet Security (CIS) benchmarks. As a minimum, Level 1 benchmarks shall be applied; all exceptions to Level 1 benchmarks shall be documented through the exception process and compensating controls shall be identified. (Refer to section 3.4 for details on the exception process.)

- 3.1.1.1 For Windows workstation or Windows operating systems with storage, apply the BitLocker benchmark configuration.
- 3.1.2 Systems and devices must be using current, vendor supported hardware, operating systems, and software.
- 3.1.3 Vendor supplied hardening guides shall be evaluated and applied based on risk.
- 3.1.4 Disable or remove unnecessary services or software.
- 3.1.5 Apply operating system, software, and **firmware** patches.
- 3.1.6 Close open or unused network **ports**.
- 3.1.7 Disable or remove unnecessary accounts.
- 3.1.8 Change all default passwords.
- 3.1.9 Where applicable, install or configure:
 - 3.1.9.1 Intrusion protection client;
 - 3.1.9.2 **Vulnerability** detection client;
 - 3.1.9.3 **Malicious code** protection client;
 - 3.1.9.4 System management client, **Security Information and Event Management (SIEM)** configuration; and
 - 3.1.9.5 Other security tools as specified by the DAS Office of Information Security and Privacy (OISP).
- 3.1.10 Systems which process or access **federal tax information** (FTI) shall be hardened and configured in accordance with IRS Publication 1075 and the applicable IRS Computer Security Evaluation Matrix available at <https://www.irs.gov/privacy-disclosure/computer-security-compliance-references-and-related-topics>.
- 3.1.11 Systems which process or access **criminal justice information** (CJI) shall be hardened and configured in accordance with FBI Criminal Justice Information System (CJIS) Security policy available at <https://www.fbi.gov/services/cjis/cjis-security-policy-resource-center>.

3.1.12 Business owners shall be consulted and may provide additional security requirements that apply to their systems based on the system data classification.

3.1.13 Systems leveraging cloud services shall also follow this standard.

3.2 Obtaining CIS Benchmark Resources

Any **user** with an e-mail address that ends in “ohio.gov” or “state.oh.us,” has the ability to login into the CIS website and create a CIS ID. From there, users can access or download the available CIS benchmarks and participate in related technical communities. Visit <https://workbench.cisecurity.org/login> to create an account.

For questions or for additional information, please contact DAS OISP (refer to Section 9.0 Inquiries for contact information).

3.3 Compliance Checking

Use the OISP provided checking tool to validate compliance settings. Access to the tool can be requested through the DAS Office of Information Technology (OIT) Customer Service Center (CSC).

3.4 Exception Process

To request an exception to one or more of the requirements outlined in this standard, please complete an IT Security Exception Request Form.

3.4.1 The form is located within the [IT Enterprise Services Portal](#) under the “Services & Products” category.

3.4.2 If you have questions, please contact DAS OISP (refer to Section 9.0 Inquires for contact information).

4.0 References

- 4.1 **Ohio IT Standard ITS-SEC-02 Security Controls Framework:** This state IT standard specifies the minimum requirements for information security in all agencies and identifies the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53 as the framework for information security controls implementation for the state.
- 4.2 **National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53; Security and Privacy Controls for Federal Information Systems**

and Organizations: NIST SP 800-53 provides guidelines for selecting and specifying security controls for federal government information systems.

- 4.3 **DAS Policy 2100-09 Configuration Management Policy:** DAS Policy 2100-09 provides configuration management requirements for DAS-managed information systems.
- 4.4 **Center for Internet Security (CIS) Benchmarks:** CIS Benchmarks are best practices for the secure configuration of a target system. Available for more than 150 technologies, CIS Benchmarks are developed through a unique consensus-based process comprised of cybersecurity professionals and subject matter experts around the world. (<https://www.cisecurity.org/cis-benchmarks/cis-benchmarks-faq/>)
- 4.5 **IRS Publication 1075, “Tax Information Security Guidelines for Federal, State and Local Agencies:”** Provides guidance to ensure the policies, practices, controls, and safeguards employed by recipient agencies, agents, or contractors adequately protect the confidentiality of federal tax information.
- 4.6 **Federal Bureau of Investigation (FBI) Criminal Justice Information System (CJIS) Security Policy:** Provides guidance to ensure the policies, practices, controls, and safeguards employed by recipient agencies, agents, or contractors adequately protect the confidentiality of criminal justice information (CJI).

5.0 Definitions

Cloud Computing Services

A service model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction.¹

Criminal Justice Information

Criminal justice information (CJI) is the abstract term used to refer to all of the FBI Criminal Justice Information Services (CJIS) provided data necessary for law enforcement agencies to perform their mission and enforce the laws, including but not limited to: biometric, identity history, person, organization, property (when accompanied by any **personally identifiable information**), and case/incident history data. In addition, CJI refers to the FBI CJIS-provided data necessary for civil

¹ Mell, Peter, Timothy Grance, “NIST Special Publication 800-145, The NIST Definition of Cloud Computing,” U.S. Department of Commerce National Institute of Standards and Technology, September 2011 <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-145.pdf>>.

agencies to perform their mission; including, but not limited to data used to make hiring decisions. The following type of data are exempt from the protection levels required for CJI: transaction control type numbers (e.g., originating identifying number (ORI), national identification number (NIC), universal control number (UCN), etc.) when not accompanied by information that reveals CJI or personally identifiable information.²

*DAS-managed
Information System*

Information systems that reside in facilities or infrastructure managed by DAS OIT personnel. Primary responsibility for managing these systems may be assigned to DAS OIT personnel or other outside entities.

*External Service
Provider*

An entity outside State of Ohio government that provides external information system or service capabilities to DAS by contract.

*Federal Tax
Information*

Federal tax information (FTI) consists of federal tax returns and return information (and information derived from it) that is in the agency's possession or control which is covered by the confidentiality protections of the IRC and subject to the IRC 6103(p)(4) safeguarding requirements including IRS oversight. FTI is categorized as Sensitive but Unclassified information and may contain personally identifiable information (PII). FTI includes return or return information received directly from the IRS or obtained through an authorized secondary source, such as Social Security Administration (SSA), Federal Office of Child Support Enforcement (OCSE), Bureau of the Fiscal Service (BFS), or Centers for Medicare and Medicaid Services (CMS), or another entity acting on behalf of the IRS pursuant to an IRC 6103(p)(2)(B) Agreement. FTI includes any information created by the recipient that is derived from federal return or return information received from the IRS or obtained through a secondary source.³

² "Criminal Justice Information Services (CJIS) Security Policy, Version 5.9," U.S. Department of Justice, Federal Bureau of Investigation, Criminal Justice Information Services Division, June 2020 <<https://www.fbi.gov/services/cjis/cjis-security-policy-resource-center>>.

³ "Publication 1075 Tax Information Security Guidelines for Federal, State and Local Agencies, Safeguards for Protecting Federal Tax Returns and Return Information," Internal Revenue Service, September 2016 <<https://www.irs.gov/pub/irs-pdf/p1075.pdf>>.

<i>Firmware</i>	Computer programs and data stored in hardware, typically in read-only memory (ROM) or programmable read-only memory (PROM), such that the programs and data cannot be dynamically written or modified during execution of the programs. ⁴
<i>Hardening</i>	Configuring a host's operating systems and applications to reduce the host's security weaknesses. ⁵
<i>Malicious Code</i>	Software or firmware intended to perform an unauthorized process that will have an adverse impact on the confidentiality, integrity, or availability of an information system. Some examples include a virus, worm, Trojan horse, or other code-based entity that infects a host. Spyware and some forms of adware are also examples of malicious code. ⁶
<i>Personally Identifiable Information</i>	"Personally identifiable information" (PII) is information that can be used directly or in combination with other information to identify a particular individual. It includes: • a name, identifying number, symbol, or other identifier assigned to a person, • any information that describes anything about a person, • any information that indicates actions done by or to a person, • any information that indicates that a person possesses certain personal characteristics.
<i>Portable Computing Device</i>	Computer or device designed for mobile use. For the purposes of this policy, a portable device includes laptops, smartphones or tablets.
<i>Ports</i>	Ports are logical addresses on a computer that allow communication using various protocols, such as FTP. Ports used in this context should not be confused with the physical

⁴ "NIST Special Publication 800-37, Risk Management Framework for Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, December 2018
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-37r2.pdf>>.

⁵ Scarfone, Karen, Wayne Jansen, Miles Tracy, "NIST Special Publication 800-123 Guide to General Server Security, Recommendations of the National Institute of Standards and Technology," U.S. Department of Commerce National Institute of Standards and Technology, July 2008
<<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-123.pdf>>.

⁶ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

serial and parallel ports used for devices such as printers, scanners and the mouse.

*Security Information
and Event Management
(SIEM)*

Application that provides the ability to gather security data from information system components and present that data as actionable information via a single interface.⁷

User

An individual or (system) process authorized to access an information system.⁸

Vulnerability

Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited by a threat source.⁹

6.0 Related Resources

Document Name
<i>Ohio IT Standard ITS-SEC-02, "Security Controls Framework"</i> https://das.ohio.gov/technology-and-strategy/policies
<i>NIST SP 800-53; "Security and Privacy Controls for Federal Information Systems and Organizations"</i> https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
<i>Center for Internet Security (CIS) Benchmarks</i> https://www.cisecurity.org/cis-benchmarks/

7.0 Implementation

7.1 DAS IT system managers are expected to work towards implementation of the secure configuration requirements outlined in this standard as quickly as possible.

7.1.1 For new information systems that are developed or acquired by DAS, the secure configuration requirements outlined in this standard shall immediately become effective.

7.1.2 For existing information systems and information system development projects that have moved beyond the requirements phase, DAS IT system

⁷ Johnson, Arnold, Kelley Dempsey, Ron Ross, Sarbari Gupta, Dennis Bailey, "NIST Special Publication 800-128, Guide for Security-Focused Configuration Management of Information Systems," U.S. Department of Commerce National Institute of Standards and Technology, October 2019 <<https://csrc.nist.gov/publications/nistpubs/800-128/sp800-128.pdf>>.

⁸ "FIPS 200, Minimum Security Requirements for Federal Information and Information Systems." Federal Information Processing Standards Publication (FIPS) March 2006. <<https://csrc.nist.gov/publications/fips/fips200/FIPS-200-final-march.pdf>>.

⁹ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations" U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

managers have one year from the effective date of this standard to implement the requirements.

- 7.1.3 If for some reason a DAS IT system manager feels that it is not technically feasible to implement the secure configuration requirements outlined in this standard, an exception request shall be submitted in accordance with Section 3.4.

8.0 Revision History

Date	Description of Changes
04/30/2020	Original Standard
09/14/2021	Conducted routine maintenance review of citations and references.
09/14/2022	Scheduled standard review.

9.0 Inquiries

For information regarding the security requirements in this DAS IT standard, please contact:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 19th Floor
Columbus, Ohio 43215

Telephone: 614.644.9391
Email: state.isp@das.ohio.gov
Web: <https://das.ohio.gov/technology-and-strategy/information-security-privacy>

DAS IT Standards are online at:
<https://das.ohio.gov/technology-and-strategy/policies>

10.0 Attachments

None.